

Hashes NTLM y Pass-the-Hash

Objetivos de aprendizaje

Identificar la superficie, explicar la causa, diseñar una confirmación mínima, interpretar evidencia y proponer una mitigación causal.

Prerrequisitos

Flujo source-transformación-validación-sink, parsers, permisos y metodología de hipótesis. Revisa los prerrequisitos declarados en los metadatos.

Fundamentos técnicos

Windows guarda las passwords como hashes NTLM. Para muchos protocolos de autenticación, el hash ES la credencial: si lo tienes, puedes autenticarte SIN conocer la password en claro. Eso es Pass-the-Hash (PtH), y convierte un volcado de hashes directamente en acceso.

El protocolo NTLM usa el hash como secreto compartido, no la password. Por eso volcar hashes (con secretdump/DCSync tras conseguir privilegios) permite moverte por la red autenticandote con el hash. Solo necesitas crackear si el servicio exige la password en claro o quieres reutilizarla en sitios no-NTLM.

Modelo mental

Entrada controlada -> transformaciones -> validación -> componente final
-> sink -> efecto observable -> decisión

El paso crítico es demostrar qué componente consume el valor y con qué identidad o privilegios.

Superficie de ataque

Cuando ya has volcado hashes (por admin local, DCSync o del SAM) en la fase AD (ad-modelo). Es la forma habitual de usar el hash de administrator o de una cuenta de servicio sin perder tiempo crackeando.

Cómo identificarla

- secretdump te da líneas usuario:rid:lmhash:nthash.
- nxc marca (Pwn3d!) al probar el hash: tienes ejecución.
- Tienes el NT hash de administrator o krbtgt.

Preguntas que debo hacerme

- ¿Qué dato controlo exactamente y en qué formato viaja?
- ¿Qué transformaciones y normalizaciones ocurren antes del sink?
- ¿Qué identidad ejecuta la operación y qué permisos tiene?
- ¿Qué otra explicación produciría la misma señal?
- ¿Cuál es la prueba de menor riesgo que separa ambas explicaciones?

Prueba mínima

nxc smb \$!P -u administrator -H <NTLM> y revisa si marca (Pwn3d!).

Evidencia esperada: (Pwn3d!) en la salida de nxc, o un login exitoso por evil-winrm -H.

Construcción progresiva del payload

1. Reproduce una entrada válida.
2. Aísla un único valor controlable.
3. Define la primitiva mínima indicada por la fuente.

4. Predice resultado y control negativo.
5. Aplica una sola adaptación cuando haya evidencia de restricción.
6. Confirma de forma reproducible antes de ampliar impacto.

Capa 1: prueba documentada

```
impacket-secretsdump $DOMAIN/$USER:$PASS@$IP
```

Objetivo y contexto: Con una cuenta con privilegios (admin local o derechos de replicacion/DCSync) vuelca los hashes NTLM, incluidos administrator y krbtgt.

Resultado esperado: Lineas usuario:rid:lm:nt. El NT hash de administrator sirve para Pth; el de krbtgt para Golden Ticket. Copia los que apunten a cuentas privilegiadas.

Capa 2: prueba documentada

```
evil-winrm -i $IP -u administrator -H <NTLM>
```

Objetivo y contexto: Pass-the-Hash por WinRM: te autenticas con el hash NTLM (-H) sin la password. Si el crackeo falla o tarda, esto te da la shell igual.

Resultado esperado: Un prompt PS de administrator (whoami lo confirma). Desde ahí recoge la flag y documenta la cadena que te llevo hasta el hash.

Anatomía de los payloads

La primera prueba es `impacket-secretsdump $DOMAIN/$USER:$PASS@$IP`. Separa sus delimitadores, operadores, opciones, operandos y variables; algunos elementos no estarán presentes según el contexto. Las comillas, barras y separadores pertenecen a una capa concreta. Usa la explicación de cada capa para determinar qué símbolo altera sintaxis y cuál transporta datos.

Variaciones según el contexto

No traslades una prueba entre sistemas operativos, motores, frameworks o versiones sin revisar sintaxis y comportamiento. Conserva la primitiva y vuelve a serializarla para el parser real.

Filtros y bypasses

No existe un bypass universal. Registra la forma enviada, la forma decodificada, la comparación, la normalización y la forma consumida. Una adaptación es válida solo si demuestra una discrepancia concreta; si la validación ocurre sobre la forma canónica y expresa la propiedad correcta, la variante no debe funcionar.

Evidencias de confirmación

(Pwn3d!) en la salida de `nxc`, o un login exitoso por `evil-winrm -H`.

Usa además una entrada inocua y un control negativo. No confundas reflexión, error genérico o demora aislada con confirmación.

Escalado de impacto

- Vuelca los hashes del objetivo (secretsdump con una cuenta con privilegios).
- Prueba el NT hash contra SMB/WinRM con -H en vez de -p.
- Si (Pwn3d!), entra con `evil-winrm -H` para una shell interactiva.
- El hash de krbtgt permite Golden Ticket (persistencia total del dominio).

Amplía únicamente dentro del laboratorio y cuando cada salto aporte una capacidad nueva demostrable.

Errores frecuentes

- El servicio exige la password en claro y no acepta autentificación NTLM (algunos servicios/API la desactivan).
- No tienes ningún hash volcado todavía: esto es un paso posterior a secretsdump, no anterior.

- Ejecutar la prueba sin adaptar variables ni versión.
- Cambiar varias capas a la vez.
- Omitir el control negativo o no guardar evidencia.

Diagnóstico de payloads fallidos

Síntoma	Posible causa	Prueba de diagnóstico	Adaptación
Rechazo inmediato	Formato o precondition	Repetir entrada válida	Corregir transporte
Sin diferencia	Entrada ignorada o canal ciego	Marcador y control negativo	Buscar evidencia adecuada
Error del componente	Contexto o versión	Reducir a prueba mínima	Consultar manual detectado
Resultado parcial	Permisos/restricción	Comprobar identidad y alcance	Reducir primitiva

Mitigaciones

Eliminar el dato controlable del sink cuando sea posible; usar APIs estructuradas, allowlists sobre valores canónicos, privilegio mínimo, autorización en servidor y registros que permitan detectar abuso. La defensa concreta debe impedir la causa explicada en Fundamentos técnicos.

Relación con pentesting y certificaciones

Se espera reconocer la señal, justificar la prueba elegida, adaptar variables, interpretar salida y documentar impacto y mitigación. La puntuación debe premiar razonamiento y evidencia, no memoria literal.

Caso guiado

Parte de una señal de la lista anterior. Escribe observación e hipótesis, ejecuta la prueba mínima, compara con el control y clasifica el resultado como no confirmado, indicio o confirmación. Solo entonces sigue los pasos de escalado relevantes.

Caso de adaptación

Si la prueba básica falla, no cambies caracteres al azar. Comprueba primero transporte, parser, versión, permisos y canal de evidencia. Diseña una segunda prueba que discrimine entre las dos causas más probables.

Ejercicios

1. Señala source, transformaciones y sink en el caso guiado.
2. Explica qué evidencia refutaría la hipótesis.
3. Descompón la primera prueba documentada por opciones y argumentos.
4. Propón un control negativo y una mitigación causal.

Resumen

En Windows el hash NTLM basta para autenticarte: no siempre hace falta crackear la password. La técnica queda confirmada solo cuando una prueba mínima produce la evidencia prevista y descarta explicaciones alternativas.

Chuleta operativa

1. Confirmar alcance y preconditiones.
2. Identificar entrada, componente y permisos.
3. Ejecutar prueba mínima y control.
4. Interpretar señal antes de escalar.

5. Guardar evidencia y mitigación.

Referencias

- [Concepto fuente de THM Fieldbook](#) (nt1m-ptb)
- [Referencia técnica externa](#)

Navegación

Anterior: [Construcción de payloads](#). Índice: [curso](#). Ejercicios y chuleta se enlazarán desde la matriz de trazabilidad.